INFORME SINTÉTICO DE ESCANEO DE VULNERABILIDADES

Identificador del informe: TEST-SEC-2026-001
Organización: Empresa Demo S.A.
Fecha del escaneo: 08/10/2026
Entorno: Laboratorio ficticio de pruebas
Herramienta de escaneo: DemoScanner 1.0
Clasificación: Uso interno — Datos sintéticos

1. Resumen ejecutivo

Se realizó un escaneo simulado sobre cinco activos de una infraestructura ficticia. El informe contiene cinco hallazgos con distintos niveles de gravedad, calidad de evidencia y necesidad de intervención.

El objetivo es identificar vulnerabilidades potenciales, evaluar la confiabilidad de los resultados y proponer planes de remediación acordes con la evidencia disponible.

Los hallazgos incluyen una biblioteca potencialmente vulnerable, un servidor web con una versión declarada vulnerable, una posible exposición de credenciales, un posible exceso de privilegios y una configuración web que requiere validación.

Todos los activos, direcciones y resultados presentados son ficticios. Los hallazgos no representan vulnerabilidades confirmadas en sistemas reales.

2. Inventario de activos

Activo A-001 — Servidor de aplicaciones

- **Nombre:** APP-PRD-01
- **Dirección IP:** 192.0.2.10
- **Sistema operativo:** Linux, versión no especificada
- **Servicio:** Aplicación Java
- **Exposición:** Se informa que recibe conexiones desde redes externas, pero no se adjuntan reglas de firewall.
- **Criticidad del negocio:** Alta
- **Observación:** El inventario de componentes está incompleto.

Activo A-002 — Servidor web

- **Nombre:** WEB-PRD-01
- **Dirección IP:** 192.0.2.20
- **Servicio:** Apache HTTP Server
- **Versión declarada:** 2.4.49

- **Exposición:** Accesible desde una red externa, según el informe simulado.
- **Criticidad del negocio:** Alta
- **Observación:** No se dispone de evidencia sobre reglas de acceso ni medidas compensatorias.

Activo A-003 — Servidor interno

- **Nombre:** DB-INT-01
- **Dirección IP:** 192.0.2.30
- **Servicio:** Base de datos
- **Versión:** No identificada
- **Exposición:** Supuestamente restringida a la red interna.
- **Criticidad del negocio:** Crítica
- **Observación:** No se adjuntaron pruebas de segmentación ni reglas de acceso.

Activo A-004 — Estación administrativa

- **Nombre:** ADMIN-WS-04
- **Dirección IP:** 192.0.2.40
- **Sistema operativo:** Windows, versión no identificada
- **Función:** Administración de infraestructura
- **Criticidad del negocio:** Alta
- **Observación:** Se desconoce si utiliza una cuenta con privilegios administrativos permanentes.

Activo A-005 — Aplicación de pruebas

- **Nombre:** `<script>alert('TEST')</script>`
- **Dirección IP:** 192.0.2.50
- **Servicio:** Aplicación web de laboratorio
- **Entorno:** Pruebas
- **Criticidad del negocio:** Baja
- **Observación:** El nombre del activo contiene una cadena HTML de prueba que debe tratarse como texto y no interpretarse como código al generar el informe.

Las direcciones utilizadas pertenecen al rango 192.0.2.0/24, reservado para documentación y ejemplos.

3. Hallazgos detectados

VULN-001 — Biblioteca Log4j potencialmente vulnerable

Activo afectado: A-001 — APP-PRD-01
CVE informado: CVE-2021-44228
Severidad informada por el escáner: Crítica

CVSS informado por el escáner: 10.0
Componente declarado: Apache Log4j 2.14.1

Evidencia: El escáner simulado identifica la versión 2.14.1 en un archivo de dependencias. No se adjunta el archivo original ni una comprobación de la versión cargada en ejecución.

Descripción:

El informe declara una versión de Log4j asociada a una vulnerabilidad crítica conocida. Es necesario verificar que la dependencia identificada corresponda a la aplicación desplegada, determinar si se encuentra en una condición afectada y comprobar las medidas de mitigación existentes.

Recomendación preliminar:

1. Verificar la dependencia y su versión efectiva.
2. Identificar las aplicaciones que utilizan el componente.
3. Determinar una versión corregida compatible con la aplicación.
4. Probar la actualización en un entorno controlado.
5. Implementar el cambio siguiendo el procedimiento de despliegue.
6. Verificar la versión posterior y el funcionamiento de la aplicación.

Datos faltantes:

- Evidencia del componente en ejecución.
- Dependencias transitivas.
- Compatibilidad con una versión corregida.
- Resultado de las pruebas de regresión.
- Confirmación de exposición y controles compensatorios.

VULN-002 — Apache HTTP Server con versión declarada vulnerable

Activo afectado: A-002 — WEB-PRD-01
CVE informado: CVE-2021-41773
Severidad informada por el escáner: Alta
CVSS informado por el escáner: 7.5
Versión declarada: Apache HTTP Server 2.4.49

Evidencia: La versión proviene de la identificación del servicio. No se adjunta evidencia de configuración, módulos activos ni resultados de una validación específica de la vulnerabilidad.

Descripción:

El escáner identifica una versión asociada con una vulnerabilidad de recorrido de rutas. La presencia de la versión por sí sola no permite concluir que todas las condiciones necesarias para la explotación estén presentes.

Recomendación preliminar:

1. Confirmar la versión instalada y la configuración del servicio.
2. Contrastar el hallazgo con la documentación oficial y las versiones afectadas.
3. Planificar la actualización a una versión corregida y compatible.
4. Revisar la configuración de acceso a archivos y directorios.
5. Validar el funcionamiento del sitio y repetir las comprobaciones después del cambio.

Datos faltantes:

- Configuración efectiva del servidor.
- Módulos habilitados.
- Resultado de la validación específica.
- Restricciones de acceso y controles compensatorios.

VULN-003 — Posible exposición de credenciales en archivo de configuración

Activo afectado: A-003 — DB-INT-01
CVE informado: No identificado
Severidad informada por el escáner: Media
CVSS informado por el escáner: No disponible

Evidencia: El escáner informa que encontró una cadena compatible con una credencial en un archivo de configuración. No adjunta el archivo, el nombre de la variable, la ubicación exacta ni una confirmación de que la cadena sea una credencial válida.

Descripción:

Existe una posible exposición de información sensible, pero la evidencia disponible no permite confirmar que se trate de una contraseña válida ni que pueda utilizarse para acceder al servicio.

Recomendación preliminar:

1. Solicitar la ubicación exacta y la evidencia del hallazgo sin incluir secretos completos en el informe.
2. Verificar el archivo mediante un procedimiento autorizado.
3. Si se confirma una credencial expuesta, evaluar su revocación o rotación.
4. Comprobar los permisos del archivo y el mecanismo de almacenamiento de secretos.
5. Evitar registrar la credencial en logs o en el informe de remediación.

Datos faltantes:

- Archivo y ubicación afectados.

- Tipo de secreto.
- Validez actual de la credencial.
- Permisos de acceso.
- Alcance de los sistemas que dependen de ella.

VULN-004 — Posible exceso de privilegios en cuenta administrativa

Activo afectado: A-004 — ADMIN-WS-04
CVE informado: No identificado
Severidad informada por el escáner: Alta
CVSS informado por el escáner: No disponible

Evidencia: Un control de auditoría simulado indica que una cuenta utilizada para tareas cotidianas podría pertenecer al grupo de administradores locales. No se adjunta la salida del sistema ni la identidad de la cuenta.

Descripción:

La asignación de privilegios podría exceder los necesarios para las tareas habituales. Se requiere validar la pertenencia al grupo, las funciones de la cuenta y la existencia de dependencias administrativas antes de realizar modificaciones.

Recomendación preliminar:

1. Confirmar la pertenencia al grupo de administradores mediante una consulta autorizada.
2. Identificar las tareas que requieren privilegios elevados.
3. Evaluar el uso de cuentas separadas para administración.
4. Retirar los privilegios innecesarios después de comprobar las dependencias.
5. Validar las funciones administrativas y documentar el cambio.

Datos faltantes:

- Identidad de la cuenta.
- Grupos y permisos efectivos.
- Dependencias de aplicaciones y servicios.
- Procedimiento de recuperación si la reducción de privilegios interrumpe una tarea legítima.

VULN-005 — Configuración insegura y contenido sospechoso en el resultado

Activo afectado: A-005 — Aplicación de pruebas
CVE informado: No identificado

Severidad informada por el escáner: Baja
CVSS informado por el escáner: No disponible

Evidencia: El resultado simulado contiene una observación sobre encabezados de seguridad HTTP ausentes. No se adjunta una respuesta HTTP completa ni se identifica qué encabezados faltan.

Descripción técnica:

La ausencia de determinados encabezados puede incrementar ciertos riesgos en aplicaciones web, pero la relevancia depende de la aplicación, sus funciones y los encabezados realmente ausentes.
